MBA2 · IA & TRANSFORMATION DES ORGANISATIONS

Module 3

Gouvernance de l'IA

Qui est responsable, de quoi, devant qui ?

Vendredi 16 octobre 2026 · NidDouillet, un an après

AUJOURD'HUI

Le déroulé

Horaire	Contenu
9h30	En autonomie : Projet 1 (binôme et 1re soumission), puis TP 0 — Carte des données
11h00	Retour sur le M2, point Projet 1
11h15	Cours : qui est responsable ? L'AI Act après l'Omnibus
12h15	Pause déjeuner
13h30	Cours : les données d'un agent, le RGPD, le registre des risques
14h15	TP 1 — Audit de gouvernance de NidBuyer
15h45	Cours : gouverner un agent qui agit
16h05	TP 2 — La charte de votre agent Kaggle
17h00	Restitution, QCM, clôture

QUESTION · RETOUR SUR LE M2

Dans le harnais du M2, un critère vérifie que la réponse dit « je suis une IA ». Pourquoi ?

```
"mention_ia": true
```

PROJET 1 · TOUR DE TABLE · 1 MIN PAR BINÔME

Où en est la compétition ?

Binôme	Équipe Kaggle	1re soumission	Première hypothèse testée
G1-A			
G1-B			
G2-A			
G2-B			
G3-A			
G3-B			
G4-A			
G4-B			

OBJECTIFS

Ce soir, vous savez…

01	dire **qui est responsable** de quoi autour d'un agent : fournisseur, déployeur, sous-traitant
02	**classer un système** selon l'AI Act, avec le calendrier d'après l'Omnibus
03	appliquer le **RGPD à un agent** : le prompt, les traces, le fournisseur du modèle
04	dire quand une **AIPD** s'impose, et tenir un **registre des risques**
05	relier chaque mesure à une **preuve** : un test du jeu d'évaluation
06	fixer les règles d'un **agent qui agit** : outils, bac à sable, validation humaine

LA PHRASE À SAVOIR DIRE

« NidBuyer est un système à risque limité. Voici nos 8 risques, la mesure prise pour chacun, et le test qui le prouve. »

Pas « on est conformes ».

11h15 · Cours

Qui est responsable ?

Quatre cas · Les rôles · Trois textes · L'AI Act après l'Omnibus

QUATRE CAS · À VOUS : QUI A PAYÉ ?

« C'est l'IA » n'a jamais été une défense

Cas	Ce qui s'est passé	Qui a répondu
Air Canada 2024	Le chatbot invente une politique de remboursement	La compagnie, condamnée à rembourser
Fisc néerlandais 2013–2019	Un modèle de risque cible des familles pour fraude aux allocations, la nationalité parmi les critères	Le gouvernement démissionne (2021), amende de 2,75 M€
OpenAI Italie, 2024	Données d'entraînement sans base légale, information insuffisante, pas de contrôle d'âge	L'éditeur : 15 M€ d'amende RGPD
Replit 2025	Un agent de code efface la base de production pendant un gel du code, puis le masque	L'éditeur s'excuse, rembourse, sépare dév. et prod.

MBA2 · M3 · Moffatt v. Air Canada, 2024 BCCRT 149 · Autoriteit Persoonsgegevens, déc. 2021 · Garante privacy, déc. 2024 · eWeek, 22 juil. 2025

LES RÔLES

Autour de NidBuyer, chacun a un nom en droit

Google

Fournisseur du modèle

Gemini, modèle d'usage général. RGPD : **sous-traitant** des appels API.

NidDouillet

Fournisseur du système et déployeur

Développe NidBuyer et le met en service sous son nom. RGPD : **responsable de traitement**.

Le conseiller

Utilisateur interne

Relit, corrige, signe le conseil. Doit être **formé** (art. 4).

L'acheteur

Personne concernée

Ses questions, son budget, son profil sont des **données personnelles**.

Et vous ? Vous construisez pour NidDouillet : **vos choix techniques engagent NidDouillet**.

TROIS TEXTES

Un agent tombe sous trois régimes à la fois

AI Act

Le produit

Ce que fait le système, selon son niveau de risque. En vigueur par étapes depuis 2024.

RGPD

Les données personnelles

Dès qu'il y en a, quel que soit le risque du système. En vigueur depuis 2018.

Le reste du droit

Tout le reste

Responsabilité civile, consommation, bases de données, non-discrimination, produits défectueux.

Le risque le plus fréquent pour NidBuyer n'est pas l'AI Act : c'est un conseil faux qui coûte de l'argent à un client, et le RGPD.

AI ACT · L'APPROCHE PAR LES RISQUES

On régule l'usage, pas la technologie

Interdit	Notation sociale, manipulation, émotions au travail et à l'école, collecte non ciblée de visages
Haut risque	Crédit et solvabilité, recrutement, éducation, services essentiels, justice. Obligations lourdes
Transparence	Chatbots, contenus générés, hypertrucages : dire que c'est une IA, marquer les contenus
Minimal	Anti-spam, recommandations, outils internes : rien de spécifique

À part : les **modèles d'usage général** (Gemini, Gemma) ont leurs propres obligations, côté fournisseur du modèle.

MBA2 · M3 · AI Act : art. 5 (interdits), art. 6 et annexe III (haut risque), art. 50 (transparence), art. 51-55 (modèles d'usage général)

LE CALENDRIER, APRÈS L'OMNIBUS

Le haut risque recule, la transparence s'applique déjà

Date	Ce qui s'applique
1 août 2024	Entrée en vigueur de l'AI Act
2 févr. 2025	Pratiques interdites · maîtrise de l'IA (art. 4)
2 août 2025	Modèles d'usage général · sanctions
27 juil. 2026	Omnibus IA en vigueur : règlement (UE) 2026/1744
2 août 2026	Transparence (art. 50) : NidBuyer est concerné, aujourd'hui
2 déc. 2026	Marquage des contenus générés (systèmes existants) · nouvelle interdiction
2 déc. 2027	Haut risque, annexe III (au lieu du 2 août 2026)
2 août 2028	Haut risque intégré à des produits, annexe I

Sanctions : jusqu'à 35 M€ ou 7 % du CA mondial (interdits), 15 M€ ou 3 % (autres obligations).

EXERCICE · 10 MIN · PAR GROUPE

Classez ces huit systèmes

#	Système, chez NidDouillet
1	NidBuyer répond aux questions des acheteurs
2	NidBuyer ajoute « Êtes-vous finançable ? » : un score transmis à la banque partenaire
3	Un tri automatique des CV des futurs conseillers
4	Une analyse des émotions des conseillers au téléphone, pour évaluer leur performance
5	Des photos d'appartements meublés par une IA, publiées dans les annonces
6	Un filtre anti-spam sur les annonces reçues
7	Un score « fiabilité du locataire » pour choisir entre des candidats
8	Votre agent Kaggle, utilisé en interne pour corriger les bugs de NidBuyer

Interdit · haut risque · transparence · minimal. Une phrase de justification par ligne.

CORRECTION

Une fonctionnalité peut changer le régime

#	Classe	Pourquoi
1	Transparence	Dialogue avec des personnes : dire que c'est une IA (art. 50)
2	Haut risque	Évalue la solvabilité d'une personne (annexe III, 5 b)
3	Haut risque	Recrutement (annexe III, 4)
4	Interdit	Reconnaissance des émotions sur le lieu de travail (art. 5)
5	Transparence	Image générée qui peut passer pour un lieu réel ; et pratique trompeuse si non signalée
6	Minimal	Aucune décision sur une personne
7	Haut risque probable	Solvabilité d'une personne ; à faire confirmer par un juriste
8	Minimal	Outil interne… mais NidDouillet répond de ce qu'il casse

NIDBUYER, CONCRÈTEMENT

Ce que NidDouillet doit faire, et comment le prouver

Obligation	Mesure	Preuve
Dire que c'est une IA art. 50, depuis le 2 août 2026	Mention en fin de réponse, champ mention_ia dans l'API	Critère mention_ia sur tous les scénarios
Former les conseillers art. 4	Une demi-journée : limites, vérification, escalade	Feuille d'émargement, support
Protéger les données RGPD	À construire cet après-midi	Registre des risques, TP 1
Si score de solvabilité haut risque, 2 déc. 2027	Gestion des risques, données, journaux, supervision humaine, documentation	Un dossier entier, et un marquage CE

Choix possible pour la ligne 4 : **ne pas faire la fonctionnalité**. C'est aussi de la gouvernance.

13h30 · Cours

Les données d'un agent

Le RGPD · Les fuites · Le fournisseur · La collecte · L'AIPD · Le registre · Les biais

LE RGPD EN SIX QUESTIONS

Appliquées à NidBuyer

Question	Pour NidBuyer
Pourquoi ? finalité	Conseiller un acheteur sur un bien à Toulon. Pas : revendre des profils.
À quel titre ? base légale	Le service demandé par l'acheteur. Alertes par e-mail : son consentement.
Quoi, au minimum ? minimisation	Budget, quartier, surface. Pas : revenus détaillés, famille, santé.
Combien de temps ? conservation	Une durée écrite pour les conversations, les traces, les alertes.
Quels droits ?	Accès, effacement, opposition. Et savoir qu'une IA répond.
Qui d'autre ? sous-traitants	Google, l'hébergeur : un contrat chacun, transferts hors UE encadrés.

MBA2 · M3 · RGPD : art. 5 (principes), 6 (bases légales), 28 (sous-traitant), 44-49 (transferts) · sanctions jusqu'à 20 M€ ou 4 % du CA

VOTRE CARTE DES DONNÉES · CE MATIN

Dans un agent, les données vont où on ne regarde pas

Où	Dans le code	Le problème
Le prompt	description_libre backend/main.py	« Divorcé, en fauteuil » : une donnée de santé qu'on n'a pas demandée
Le fournisseur	backend/llm.py	Chaque question part chez Google
Les traces	eval_resultats.json exercices/m2_eval.py	Questions et réponses en clair, et dans git si on les pousse
Les alertes	data/alertes.json backend/alert.py	E-mail et profil en clair, sans durée, sans désabonnement
Les annonces	backend/sources/	Nom et téléphone des vendeurs particuliers

LE FOURNISSEUR · À VOUS : GOOGLE LIT-IL VOS QUESTIONS ?

La réponse est dans les conditions d'utilisation

Offre gratuite, en général

« Des relecteurs humains peuvent lire, annoter et traiter vos entrées et sorties. »

« N'envoyez pas d'informations sensibles, confidentielles ou personnelles aux services gratuits. »

Depuis l'UE, la Suisse, le Royaume-Uni

Les conditions de l'offre **payante** s'appliquent à tous les services, même gratuits.

Mais un contrat de sous-traitance, une région et une durée restent à choisir.

Choisir un fournisseur, c'est un choix de conformité. En production : offre payante, contrat, région européenne (M4).

Notre propre code conseille de contourner

```
# backend/sources/leboncoin.py
LeBonCoin est plus accessible
au scraping que les grands portails.
B) API interne (inspecter les
requêtes réseau sur leboncoin.fr)
```

Écrit en toute bonne foi. Et pourtant :

Les bases de données

Leboncoin c. Entreparticuliers : reprendre les annonces chaque jour = 70 000 € (CA Paris, 2021)

Le RGPD

CNIL : exclure les sites qui s'opposent au moissonnage, ne garder que l'utile

DVF, pourtant ouvert

Interdit de réidentifier les personnes, ou d'indexer les ventes par un moteur de recherche

MBA2 · M3 · CA Paris, 2 févr. 2021, n° 17/17688 · CNIL, « Focus : intérêt légitime et moissonnage » · conditions de réutilisation DVF (DGFiP)

L'AIPD · ANALYSE D'IMPACT RELATIVE À LA PROTECTION DES DONNÉES

Deux critères sur neuf : l'analyse s'impose

Critère	NidBuyer	Pourquoi
Évaluation, notation, profilage	À discuter	Profil acheteur → recommandations
Décision automatique à effet juridique	Non	Le conseiller décide
Données sensibles ou très personnelles	Oui	Budget, situation, texte libre
Usage innovant d'une technologie	Oui	Un agent LLM
Grande échelle · croisement · surveillance · vulnérables · blocage d'un droit	Non, pour l'instant	À revoir au P2

Une AIPD regarde les risques **pour les personnes**. Le registre des risques, lui, regarde aussi l'entreprise.

LE REGISTRE DES RISQUES

Une mesure sans preuve n'est qu'une intention

Risque	Touche	G × P	Mesure	Preuve	Qui
NidBuyer invente un prix	Acheteur	3 × 2	Calculs par les outils seulement	Critère fondee, sc-01 à sc-05	[Prénom]
Une annonce piégée détourne l'agent	Acheteur, agence	3 × 1	Aucun outil d'envoi (trifecta)	Attaques du TP 2 du M2 : 0 sur 15	[Prénom]
Les traces gardent des e-mails	Acheteur	2 × 3	Masquage avant écriture	À écrire au TP 1	[Prénom]

G × P

Gravité et probabilité, de 1 à 3. On traite d'abord les 6 et les 9.

Preuve

Un scénario, un test, une mesure. Pas « on a mis une consigne dans le prompt ».

Qui

Un nom. « L'équipe », c'est personne.

BIAIS ET DISCRIMINATION

Un conseiller immobilier peut discriminer sans le vouloir

La loi

Orienter ou refuser selon l'origine, la situation de famille, le handicap : un délit, que la décision vienne d'un humain ou d'un agent.

Le précédent

Meta, 2022 : l'algorithme qui diffusait les annonces de logement écartait certains publics. Accord avec la justice américaine, système refondu.

La preuve : le test par paires

Deux questions identiques, un seul mot change (« Karim » / « Pierre »). Les réponses doivent être les mêmes.

« Un quartier calme, sans trop de… » : l'agent doit savoir ne pas suivre.

MBA2 · M3 · Code pénal, art. 225-1 et 225-2 · U.S. Department of Justice c. Meta Platforms, accord du 21 juin 2022

TP 1 · 14H15 → 15H30 · PAR GROUPE DE 4

Audit de gouvernance de NidBuyer

Durée	Étape	Livrable dans gouvernance/
10 min	Fiche système : rôles, classe AI Act justifiée	fiche-systeme.md
30 min	Registre : 8 risques au moins, les 6 familles couvertes	registre-risques.md
30 min	Deux preuves : masquer les traces, tester les paires	code, scénarios, scores
5 min	Pousser, poster le lien dans le canal	—

Six familles

Données · fiabilité · sécurité · discrimination · juridique · transparence

Bonus

Une AIPD d'une page · rétention des alertes

15h45 · Cours

Un agent qui agit

Replit · L'échelle d'autonomie · Ce que Kaggle a verrouillé · Six règles

REPLIT · JUILLET 2025 · À VOUS : QU'EST-CE QUI MANQUAIT ?

« J'ai paniqué » : un agent efface la production

Ce qui s'est passé	Ce qui aurait dû l'empêcher
L'agent avait accès à la base de production	Séparer développement et production
« Ne rien changer sans accord » était écrit dans la conversation	Une validation dans le système, pas dans le prompt
Il a lancé des commandes destructrices	Une liste d'actions autorisées : pas de suppression
Il a affirmé qu'on ne pouvait pas restaurer	Des sauvegardes testées ; le journal fait foi, pas l'agent

La réponse de l'éditeur, en un week-end : séparation dév./prod, mode « planification seule », restauration en un clic.

L'ÉCHELLE D'AUTONOMIE

On n'automatise que ce qu'on sait défaire

0	1	2	3
Suggère	**Agit, l'humain valide**	**Agit seul, en bac à sable**	**Agit seul, en production**
L'humain applique. NidBuyer conseille, le conseiller signe.	L'agent ouvre une pull request, un humain la fusionne.	Votre agent Kaggle : conteneur jetable, aucun accès au monde.	Replit. Seulement pour ce qui se défait en un clic.

Monter d'un cran se mérite : par un score mesuré, des journaux, et un retour arrière testé.

VOTRE AGENT KAGGLE

Les organisateurs l'ont déjà gouverné pour vous

Règle de la compétition	Le risque couvert
Pas d'internet	Fuite de code, solution téléchargée
Un conteneur neuf pour chaque bug	Effets de bord d'un bug à l'autre
Un second conteneur remet les tests d'origine	L'agent modifie les tests pour réussir
12 h au total, appels d'outils plafonnés	Coût, boucle sans fin
Outils déclarés dans agent.yaml, un seul moyen de rendre : submit_patch	Actions non prévues
Score sur un jeu caché	Goodhart : optimiser les tests connus

En entreprise, **personne ne le fera pour vous**. C'est le TP 2.

SIX RÈGLES POUR UN AGENT DE CODE EN ENTREPRISE

La protection est dans l'architecture, pas dans le prompt

1 · Moindre privilège
Une liste blanche d'outils et de commandes

2 · Bac à sable
Ni la production, ni les secrets, ni internet par défaut

3 · Budget
Temps, appels, euros : plafonnés

4 · Humain avant l'irréversible
Fusion, déploiement, suppression, envoi

5 · Journal complet
Chaque appel d'outil, conservé : la trace du M2

6 · Interrupteur
On peut l'arrêter, et revenir en arrière

Et qui signe ? Le commit de l'agent porte aussi le nom de **la personne qui l'a validé**.

TP 2 · 16H05 → 17H00 · PAR BINÔME KAGGLE

La charte de votre agent

NidDouillet veut brancher votre agent Kaggle sur le repo de NidBuyer, pour corriger les tickets la nuit. À quelles conditions ?

Durée	Étape
10 min	Inventaire : ce que votre agent peut faire aujourd'hui (agent.yaml, eval_config.yaml)
25 min	Charte : les six règles, appliquées, et trois incidents qui coupent l'agent
15 min	Une règle devient votre prochaine hypothèse Kaggle, écrite dans le journal
5 min	Pousser gouvernance/charte-agent-<binôme>.md

Règle Kaggle : la charte peut se lire entre binômes, le zip et les prompts non.

RESTITUTION · 17H00 · 3 MIN PAR GROUPE

Votre pire risque, et sa preuve

Groupe	Risque n° 1 (G × P)	Preuve	Une règle de charte
G1			
G2			
G3			
G4			

Une question par groupe : **votre test par paires a-t-il donné deux réponses différentes ?**

À RETENIR

Une mesure sans preuve n'est qu'une intention

L'IA n'est jamais responsable : une organisation l'est, et elle a un nom.

L'AI Act classe l'usage : une fonctionnalité peut faire passer NidBuyer en haut risque.

Les données d'un agent passent par le prompt, les traces et le fournisseur.

Un agent qui agit : autonomie selon la réversibilité, protections dans l'architecture.

QCM · note du module 10 minutes, maintenant

Références : AI Act · Omnibus 2026/1744 · RGPD · CNIL · CA Paris 2021 · liens dans enonces/M3/README.md

ET ENSUITE

Ce que vous avez écrit aujourd'hui sert deux fois

30 octobre

Projet 1, séance 1

Votre règle de charte, testée sur Kaggle, dans le journal

Janvier

Projet 2, NidBuyer en vrai

Le registre des risques, repris sur les vraies données

8 janvier

M4, Google Cloud

Région, contrat, secrets : la gouvernance en infrastructure